



File No.: EXP202306096

RESOLUTION OF SANCTIONING PROCEDURE

From the procedure instructed by the Spanish Agency for Data Protection and based on the following

FACTS

FIRST: A.A.A. (hereinafter, the complainant) filed a complaint with the Spanish Agency for Data Protection on March 24, 2023. The complaint is directed against the ASSOCIATION OF PROFESSIONALS OF PRIVATE SECURITY OF SPAIN with NIF G67820456. The reasons for the complaint are as follows:

The complainant, who is part of the board of directors of the association of private security professionals in Spain, reports the sending of several email messages sent, each of them, by the president of the association to a single recipient (a member who apparently had expressed not understanding actions taken by the president and the board of directors). In these messages, the rest of the board members, including the complainant, were copied, who complains that his personal email address was used instead of the one linked to the association's domain.

SECOND: In accordance with Article 65.4 of Organic Law 3/2018, of December 5, on Personal Data Protection and Guarantee of Digital Rights (hereinafter LOPDGDD), the complaint was forwarded to the association of private security professionals of Spain, so that it could analyze it and inform this Agency within one month of the actions taken to comply with the requirements set forth in data protection regulations.

The forwarding, which was carried out in accordance with the rules established in Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter, LPACAP) by electronic notification, was not collected by the responsible party within the availability period, being understood as rejected, in accordance with the provisions of Article 43.2 of the LPACAP, on May 28, 2023, according to the certificate in the file.

Although the notification was validly carried out by electronic means, considering the procedure completed in accordance with the provisions of Article 41.5 of the LPACAP, an informational copy was sent by postal mail, which was marked as "Delivered" on June 22, 2023. In this notification, the obligation to communicate electronically with the Administration was reminded, and the means of access to such notifications were informed, reiterating that, henceforth, notifications would be made exclusively by electronic means.

No response has been received to this forwarding letter.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

THIRD: On June 24, 2023, in accordance with Article 65 of the LOPDGDD, the complaint filed by the complainant was admitted for processing.

FOURTH: On October 3, 2023, the Director of the Spanish Agency for Data Protection decided to initiate sanctioning proceedings against the respondent for the alleged infringement of Article 5.1.f) of the GDPR and Article 32 of the GDPR, classified under Article 83.5 of the GDPR and Article 83.4 of the GDPR.

FIFTH: The aforementioned initiation agreement was notified on October 13, 2023, as stated in the acknowledgment of receipt in the file, in accordance with the rules established in the LPACAP, and after the period granted for the submission of allegations had elapsed, it has been confirmed that no allegations have been received from the respondent.

Article 64.2.f) of the LPACAP - a provision of which the respondent was informed in the initiation agreement - establishes that if no allegations are made within the stipulated period regarding the content of the initiation agreement, when it contains a precise statement regarding the responsibility

attributed, it may be considered a proposal for resolution. In this case, the initiation agreement of the sanctioning file determined the facts that specified the accusation, the infringement of the GDPR attributed to the respondent, and the sanction that could be imposed. Therefore, considering that the respondent has not made allegations against the initiation agreement of the file and in accordance with the provisions of Article 64.2.f) of the LPACAP, the aforementioned initiation agreement is considered in this case as a proposal for resolution.

In light of all that has been acted upon, the Spanish Agency for Data Protection considers the following facts proven in this procedure,

PROVEN FACTS

FIRST: The president of the Association of Private Security Professionals of Spain sent several email messages to a single recipient (a member who apparently had expressed not understanding actions taken by the president and the board of directors). In these messages, the rest of the board members, including the complainant, were copied, who complains that his personal email address was used instead of the one linked to the association's domain.

LEGAL GROUNDS

I

Competence

In accordance with the powers granted to each supervisory authority by Article 58.2 of Regulation (EU) 2016/679 (General Data Protection Regulation, hereinafter GDPR), and as established in Articles 47, 48.1, 64.2, and 68.1 of the

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

3/8

Organic Law 3/2018, of December 5, on the Protection of Personal Data and Guarantee of Digital Rights (hereinafter, LOPDGDD), grants competence to initiate and resolve this procedure to the Director of the Spanish Agency for the Protection of Data.

Furthermore, Article 63.2 of the LOPDGDD states: "The procedures processed by the Spanish Agency for the Protection of Data shall be governed by the provisions of Regulation (EU) 2016/679, by this organic law, by the regulatory provisions issued for its development, and, as long as they do not contradict them, subsidiarily by the general rules on administrative procedures."

II

Unfulfilled Obligation

The known facts are considered to constitute an infringement, attributable to the association of private security professionals in Spain, classified under Article 5.1.f) of the GDPR and Article 32 of the GDPR. Firstly, Article 5 of the GDPR establishes the principles that must govern the processing of personal data, and secondly, Article 32 of the GDPR regulates the security of processing.

III.

Article 5.1.f)

Article 5.1.f) "Principles relating to processing" of the GDPR states:

"1. Personal data shall be:

f) processed in a manner that ensures appropriate security of the personal data, including protection against unauthorized or unlawful processing and against accidental loss, destruction, or damage, through the application of appropriate technical or organizational measures ('integrity and confidentiality')."

In accordance with the evidence available at this moment of resolution of the sanctioning procedure, it is considered that the association of private security professionals in Spain has processed personal data of the complainant, without adopting the technical and organizational measures, of all kinds, required by the regulations on the protection of personal data, by sending emails to a plurality of persons using personal email accounts and not those linked to the association's domain, violating the

confidentiality in the processing of personal data and therefore this fact constitutes an infringement for violation of Article 5.1.f) of the GDPR.

IV

Classification and Qualification of the Infringement of Article 5.1.f) of the GDPR

The aforementioned infringement of Article 5.1.f) of the GDPR constitutes the commission of one of the infringements classified in Article 83.5 of the GDPR which under the heading "General conditions for the imposition of administrative fines" states:

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

4/8

"Violations of the following provisions shall be sanctioned, in accordance with paragraph 2, with administrative fines of up to 20,000,000 EUR or, in the case of an enterprise, an amount equivalent to 4% of the total annual global turnover of the previous financial year, opting for the higher amount:
a) the basic principles for processing, including the conditions for consent under Articles 5, 6, 7, and 9; (...)"

In this regard, the LOPDGDD, in its Article 71 "Infringements" establishes that:

"Acts and conduct referred to in paragraphs 4, 5, and 6 of Article 83 of Regulation (EU) 2016/679, as well as those that are contrary to this organic law, constitute infringements."

For the purposes of the statute of limitations, Article 72 "Infringements considered very serious" of the LOPDGDD indicates:

"1. In accordance with what is established in Article 83.5 of Regulation (EU) 2016/679, the following shall be considered very serious and shall be subject to a three-year statute of limitations: infringements that constitute a substantial violation of the articles mentioned therein and, in particular, the following:

a) The processing of personal data in violation of the principles and guarantees established in Article 5 of Regulation (EU) 2016/679. (...)"

V

Sanction for the Infringement of Article 5.1.f) of the GDPR

Article 83 "General conditions for the imposition of administrative fines" of the GDPR paragraph 5 states:

"5. Violations of the following provisions shall be sanctioned, in accordance with paragraph 2, with administrative fines of up to 20,000,000 EUR or, in the case of an enterprise, an amount equivalent to 4% of the total annual global turnover of the previous financial year, opting for the higher amount:
a) the basic principles for processing, including the conditions for consent under Articles 5, 6, 7, and 9; (...)"

VI

Article 32 of the GDPR

Article 32 "Security of processing" of the GDPR states:

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

5/8

"1. Taking into account the state of the art, the costs of application, and the nature, scope, context, and purposes of the processing, as well as the variable probability and severity risks to the rights and freedoms of natural persons, the controller and the processor shall implement appropriate technical and organizational measures to ensure a level of security appropriate to the risk, which may include, among others:

a) the pseudonymization and encryption of personal data;

- b) the ability to ensure the confidentiality, integrity, availability, and permanent resilience of processing systems and services;
- c) the ability to restore the availability and access to personal data quickly in the event of a physical or technical incident;
- d) a process for the regular verification, evaluation, and assessment of the effectiveness of the technical and organizational measures to ensure the security of processing.

2. In assessing the appropriateness of the level of security, particular attention shall be paid to the risks presented by the data processing, in particular as a result of the accidental or unlawful destruction, loss, or alteration of personal data transmitted, stored, or otherwise processed, or the unauthorized communication or access to such data.

3. Adherence to an approved code of conduct pursuant to Article 40 or to an approved certification mechanism pursuant to Article 42 may serve as an element to demonstrate compliance with the requirements set out in paragraph 1 of this article.

4. The controller and the processor shall take measures to ensure that any person acting under the authority of the controller or the processor and having access to personal data may only process such data on instructions from the controller, unless required to do so by Union or Member State law.”

In accordance with the evidence available at this time regarding the resolution of the sanctioning procedure, it is considered that, in this case, there is no indication that the association of private security professionals in Spain had appropriate technical and organizational security measures in relation to the use of corporate and personal email accounts based on the estimated potential risks and, therefore, the known facts constitute an infringement for violation of Article 32 of the GDPR. Security measures that are deemed inappropriate, even though personal data of the claimant had not been communicated to a third party.

VII

Classification and qualification of the infringement of Article 32 of the GDPR

The aforementioned infringement of Article 32 of the GDPR constitutes the commission of one of the infringements classified in Article 83.4 of the GDPR, which under the heading “General conditions for the imposition of administrative fines” provides:

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

6/8

“The infringements of the following provisions shall be sanctioned, in accordance with paragraph 2, with administrative fines of up to 10,000,000 EUR or, in the case of an enterprise, an amount equivalent to a maximum of 2% of the total annual global turnover of the previous financial year, opting for the higher amount:

- a) the obligations of the controller and the processor under Articles 8, 11, 25 to 39, 42, and 43; (...)”

In this regard, the LOPDGDD, in its Article 71 “Infringements” establishes that “Acts and behaviors referred to in paragraphs 4, 5, and 6 of Article 83 of Regulation (EU) 2016/679, as well as those that are contrary to this organic law, constitute infringements.”

For the purposes of the limitation period, Article 73 “Infringements considered serious” of the LOPDGDD indicates:

“Based on what is established in Article 83.4 of Regulation (EU) 2016/679, the following infringements are considered serious and shall be subject to a limitation period of two years:

- f) The failure to adopt those technical and organizational measures that are appropriate to ensure a level of security appropriate to the risk of processing, as required by Article 32.1 of Regulation (EU) 2016/679.” (...)

VIII

Sanction for the infringement of Article 32 of the GDPR

Article 83 “General conditions for the imposition of administrative fines” of the GDPR, paragraph 4, establishes:

4. The infringements of the following provisions shall be sanctioned, in accordance with paragraph 2, with administrative fines of up to 10,000,000 EUR or, in the case of an enterprise, an amount equivalent to a maximum of 2% of the total annual global turnover of the previous financial year, opting for the higher amount:

a) the obligations of the controller and the processor under Articles 8, 11, 25 to 39, 42, and 43;

IX

Imposed sanction

In light of the facts presented, it is considered appropriate to impose a sanction on the party claimed for the violation of Article 5.1.f) of the GDPR and Article 32 of the GDPR classified in Article 83.5 of the GDPR and Article 83.4 of the GDPR. The sanction to be imposed is an administrative fine in the amount of one thousand five hundred

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

7/8

euros (€1,500.00) for the infringement of Article 5.1.f) and five hundred euros (€500.00) for the infringement of Article 32.

Therefore, in accordance with the applicable legislation and having assessed the criteria for the graduation of the sanctions whose existence has been established,

the Director of the Spanish Agency for Data Protection RESOLVES:

FIRST: TO IMPOSE on the ASSOCIATION OF PRIVATE SECURITY PROFESSIONALS OF SPAIN, with NIF G67820456, a fine of one thousand five hundred euros (€1,500.00) for the infringement of Article 5.1.f) of the GDPR and five hundred euros (€500.00) for the infringement of Article 32, classified under Article 83.5 of the GDPR and Article 83.4 of the GDPR.

SECOND: TO NOTIFY this resolution to the ASSOCIATION OF PRIVATE SECURITY PROFESSIONALS OF SPAIN.

THIRD: This resolution will be enforceable once the period for filing the optional appeal for reconsideration (one month from the day following the notification of this resolution) has expired without the interested party having exercised this right. The sanctioned party is warned that they must pay the imposed sanction once this resolution becomes enforceable, in accordance with the provisions of Article 98.1.b) of Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter LPACAP), within the voluntary payment period established in Article 68 of the General Collection Regulation, approved by Royal Decree 939/2005, of July 29, in relation to Article 62 of Law 58/2003, of December 17, by depositing it, indicating the NIF of the sanctioned party and the procedure number that appears in the heading of this document, into the restricted account No.

IBAN: ES00-0000-0000-0000-0000-0000 (BIC/SWIFT Code: CAIXESBBXXX), opened in the name of the Spanish Agency for Data Protection at the banking entity CAIXABANK, S.A. Otherwise, collection will proceed in the executive period.

Upon receipt of the notification and once enforceable, if the date of enforceability falls between the 1st and the 15th of each month, inclusive, the deadline for voluntary payment will be until the 20th of the following month or the next business day thereafter, and if it falls between the 16th and the last day of each month, inclusive, the payment deadline will be until the 5th of the second following month or the next business day thereafter.

In accordance with the provisions of Article 50 of the LOPDGDD, this Resolution will be made public once it has been notified to the interested parties.

Against this resolution, which concludes the administrative procedure in accordance with Article 48.6 of the LOPDGDD, and in accordance with the provisions of Article 123 of the LPACAP, the interested parties may optionally file an appeal for reconsideration before the Director of the Spanish Agency for Data Protection within one month from the day following the notification of this resolution or directly file a contentious-administrative appeal before the Contentious-Administrative Chamber of the National Court, in accordance with the provisions of Article 25 and section 5 of the fourth additional provision of

Law 29/1998, of July 13, regulating Contentious-Administrative Jurisdiction, within two months from the day following the notification of this act, as provided in Article 46.1 of the aforementioned Law. Finally, it is noted that in accordance with the provisions of Article 90.3 a) of the LPACAP, the firm resolution in the administrative procedure may be provisionally suspended if the interested party expresses their intention to file a contentious-administrative appeal. If this is the case, the interested party must formally communicate this fact by writing to the Spanish Agency for Data Protection, submitting it through the Electronic Registry of the Agency [<https://sedeagpd.gob.es/sede-electronica-web/>], or through any of the other registries provided for in Article 16.4 of the aforementioned Law 39/2015, of October 1. They must also provide the Agency with documentation that proves the effective filing of the contentious-administrative appeal. If the Agency does not have knowledge of the filing of the contentious-administrative appeal within two months from the day following the notification of this resolution, it will consider the provisional suspension to be concluded.

938-21112023

Mar España Martí

Director of the Spanish Agency for Data Protection

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es